Trabajo Práctico - Semana 3: Gestión de Riesgos en Sistemas de Información

Nombre Alumno: Torres Martin

Enunciado y Consigna

Lea atentamente el siguiente texto. El mismo contiene errores conceptuales relacionados con la gestión de riesgos en sistemas de información.

- **Identifique errores.**
- **Corríjalos en una o dos líneas cada uno.**

Texto para análisis

> En una organización, la gestión de riesgos suele abordarse **comenzando directamente por el análisis de las amenazas, asumiendo que estas son el elemento central del problema y que no resulta necesario identificar previamente los activos de información involucrados**. Desde esta perspectiva, una vez que se detectan las amenazas, **el siguiente paso consiste en estimar el impacto, el cual se calcula principalmente en función de la probabilidad de ocurrencia**, sin profundizar en las dimensiones específicas de Confidencialidad, Integridad y Disponibilidad. En este enfoque, **los activos se clasifican asignándoles un único valor de impacto general, considerando que las distintas dimensiones de seguridad afectan de manera similar y que no es necesario analizarlas por separado**. En consecuencia, **la probabilidad de que ocurra un evento adverso se asocia directamente al activo, dado que se entiende que depende del valor o criticidad del sistema** que se busca proteger. Asimismo, al momento de evaluar el riesgo, **se considera que el riesgo bruto es aquel que resulta luego de aplicar controles de seguridad, mientras que el riesgo residual corresponde al escenario inicial en ausencia de dichos controles**. En línea con esto, **las salvaguardas se interpretan como mecanismos que incrementan la probabilidad de ocurrencia de incidentes, con el objetivo de facilitar su detección y análisis**. Finalmente, **la construcción de la matriz de riesgo se realiza de manera cualitativa, sin necesidad de definir escalas numéricas ni criterios formales de clasificación.**

Identificación y Corrección de Errores Conceptuales

1. Error sobre el punto de partida de la gestión de riesgos

> **Texto original erróneo:** "*...comenzando directamente por el análisis de las amenazas, asumiendo que estas son el elemento central del problema y que no resulta necesario identificar previamente los activos de información involucrados.*"

- **Error identificado:** Sostener que la gestión de riesgos puede comenzar directamente con el análisis de amenazas sin identificar previamente los activos de información involucrados.
- **Corrección:** La identificación y valoración de activos es el punto de partida obligatorio de todo análisis de riesgos; es conceptualmente imposible proteger o gestionar el riesgo sobre aquello que la organización desconoce.

2. Error en la relación entre el impacto y la probabilidad

> **Texto original erróneo:** "*...el siguiente paso consiste en estimar el impacto, el cual se calcula principalmente en función de la probabilidad de ocurrencia...*"

- **Error identificado:** Afirmar que el impacto se calcula principalmente en función de la probabilidad de ocurrencia de la amenaza.
- **Corrección:** El impacto mide el nivel de daño sobre las dimensiones de seguridad del activo afectado, mientras que la probabilidad estima la verosimilitud de ocurrencia del evento; son variables de análisis independientes.

3. Error en la unificación del impacto de la tríada CID

> **Texto original erróneo:** "*...los activos se clasifican asignándoles un único valor de impacto general, considerando que las distintas dimensiones de seguridad afectan de manera similar y que no es necesario analizarlas por separado.*"

- **Error identificado:** Sostener que los activos se clasifican con un único valor de impacto general asumiendo que las dimensiones de la tríada afectan de forma similar.
- **Corrección:** Cada activo debe valorarse de forma independiente en Confidencialidad, Integridad y Disponibilidad, ya que la gravedad y consecuencias de un incidente difieren notablemente según la dimensión vulnerada.

4. Error sobre el origen de la probabilidad de ocurrencia

> **Texto original erróneo:** "*...la probabilidad de que ocurra un evento adverso se asocia directamente al activo, dado que se entiende que depende del valor o criticidad del sistema...*"

- **Error identificado:** Indicar que la probabilidad de ocurrencia se asocia al activo y depende de su valor o criticidad intrínseca.
- **Corrección:** La probabilidad depende de la frecuencia de la amenaza y de las vulnerabilidades presentes en el entorno, siendo independiente de cuán valioso o crítico sea el activo para la organización.

5. Error de inversión entre Riesgo Bruto y Riesgo Residual

> **Texto original erróneo:** "*...se considera que el riesgo bruto es aquel que resulta luego de aplicar controles de seguridad, mientras que el riesgo residual corresponde al escenario inicial en ausencia de dichos controles.*"

- **Error identificado:** Invertir las definiciones sosteniendo que el riesgo bruto resulta de aplicar controles y que el residual corresponde al escenario inicial sin salvaguardas.
- **Corrección:** El riesgo bruto (o inherente) es el nivel de exposición inicial en ausencia de controles, mientras que el riesgo residual es el remanente que subsiste tras implementar las salvaguardas.

6. Error sobre la función operativa de las salvaguardas

> **Texto original erróneo:** "*...las salvaguardas se interpretan como mecanismos que incrementan la probabilidad de ocurrencia de incidentes, con el objetivo de facilitar su detección y análisis.*"

- **Error identificado:** Afirmar que las salvaguardas incrementan la probabilidad de incidentes para facilitar su detección.
- **Corrección:** Las salvaguardas o controles son medidas orientadas a reducir la probabilidad de ocurrencia de una amenaza y/o mitigar el impacto negativo en caso de que el incidente se materialice.

7. Error sobre la formalidad de las escalas en la matriz de riesgo

> **Texto original erróneo:** "*...la construcción de la matriz de riesgo se realiza de manera cualitativa, sin necesidad de definir escalas numéricas ni criterios formales de clasificación.*"

- **Error identificado:** Sostener que un análisis cualitativo exime de definir escalas y criterios formales de clasificación.
- **Corrección:** Aunque la matriz sea cualitativa, es indispensable definir y documentar previamente criterios y escalas formales (baja, media, alta) para evitar la subjetividad y garantizar resultados comparables y auditables.